

Narrativa Explicativa – GQM + PRAGMATIC aplicado a TRIKE

1. De los grandes objetivos a los datos tozudos

Hablar de “resiliencia nacional” o de “fortalecer la ciberseguridad de los sectores esenciales” suena magnífico en comunicados de prensa, pero resulta peligrosamente vago cuando uno intenta decidir qué medir, con qué datos, y para qué. [web:16][web:41]

El enfoque GQM nos obliga a recorrer el camino en la dirección correcta: primero el objetivo (Goal), después las preguntas (Question) y solo al final las métricas (Metric). [web:38]

Es decir: nada de inventar indicadores ingeniosos y confiar en que, algún día, alguien sabrá para qué servían.

2. TRIKE como esqueleto, GQM como sistema nervioso

Las cinco letras de TRIKE –Threat, Risk, Impact, Knowledge, Evaluation– proporcionan el esqueleto conceptual: aquello que un país, un sector o una organización debe ser capaz de pensar y medir si quiere tomarse en serio la ciberseguridad.

GQM, por su parte, actúa como sistema nervioso: conecta los objetivos políticos (menos incidentes graves, mejor preparación ante NIS2, mayor confianza digital) con preguntas concretas y datos observables. [web:23][web:43]

En la práctica, formular “Goal T1: Mejorar el conocimiento y la monitorización de la intensidad y naturaleza de las amenazas” conduce a preguntas como “¿cuántos incidentes tenemos por sector y tipo de entidad?” y, de ahí, a métricas como “incidentes por 100.000 habitantes” o “incidentes significativos NIS2 por tipo de entidad”. [web:22][web:44][web:46]

3. PRAGMATIC: la criba saludable

Un peligro frecuente en programas nacionales de ciberseguridad es caer en la inflación de métricas: cada informe añade columnas, cada actor propone su indicador favorito, y al cabo de pocos años nadie recuerda qué significa cada número.

Los criterios PRAGMATIC, desarrollados en el ámbito de las metametrics de seguridad, ofrecen una criba razonable: predecible, relevante, accionable, genuino, significativo, preciso, oportuno, independiente y rentable. [web:39][web:42][web:45]

Aplicar PRAGMATIC a las métricas TRIKE tiene un efecto higiénico: obliga a preguntarse, por cada indicador, si realmente ayuda a anticipar problemas, si está vinculado a decisiones concretas, si depende de datos confiables y si su obtención no cuesta más de lo que aporta. [web:47]

4. Ejemplo ilustrativo: incidentes por 100.000 habitantes

Tomemos la métrica T1.1.a: número de incidentes de ciberseguridad por 100.000 habitantes y por sector crítico, basada en datos de INCIBE, CCN-CERT y otros CSIRTs. [web:22][web:46]

- Como métrica GQM, responde directamente a la pregunta sobre intensidad de amenazas y al objetivo de monitorizar el panorama a escala país.
- Bajo PRAGMATIC, resulta altamente relevante y significativa, razonablemente predictiva (si las tendencias se mantienen) y bastante accionable para priorizar recursos sectoriales.
- Su precisión y oportunidad dependen de la calidad y puntualidad del reporte de incidentes, pero esa dependencia es precisamente uno de los motivos para mejorar la coordinación y la obligatoriedad de notificación. [web:23][web:43]

Es decir: una métrica que, más allá del titular de “más de 97.000 incidentes”, permite observar patrones territoriales y sectoriales con cierta finura. [web:22]

5. Del compliance al gobierno inteligente del riesgo

NIS2, el anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad y las guías de ENISA son claros: la meta no es acumular documentos, sino demostrar que se gestionan los riesgos de forma sistemática y proporcionada. [web:23][web:41][web:44]

En este contexto, un programa de indicadores basado en GQM + PRAGMATIC y estructurado con TRIKE permite:

- Traducir obligaciones legales en objetivos medibles y comparables.
- Demostrar avances (o retrocesos) con una narrativa apoyada en datos, no solo en percepciones.
- Identificar dónde duele más: si en la amenaza (T), en la falta de métricas de riesgo (R), en la incapacidad de cuantificar impacto (I), en el déficit de conocimiento (K) o en la debilidad de los ciclos de evaluación (E).

6. Evitar la trampa de los indicadores “bonitos pero inútiles”

El enfoque PRAGMATIC nos recuerda, con cierta ironía, que no todas las métricas nacen iguales. [web:45][web:47]

Algunas son fáciles de obtener y lucen bien en gráficos, pero dicen poco sobre el estado real de la ciberseguridad o sobre qué hacer mañana.

Por eso, en la matriz propuesta se tiende a priorizar indicadores como:

- Pérdida económica esperada por sector.
- Duración media de interrupciones en servicios esenciales.
- Porcentaje de incidentes con post-mortem documentado.
- Número de hallazgos de supervisión regulatoria por categoría. [web:23][web:44]

Son métricas que quizá no sean las más cómodas de explicar, pero que difícilmente pueden ignorarse cuando se habla de resiliencia real.

7. Una invitación (ligeramente provocadora)

Este marco no pretende ser definitivo ni perfecto.

Sí aspira, sin embargo, a elevar la conversación nacional sobre indicadores de ciberseguridad por encima de la enumeración ocasional de incidentes sonoros.

La invitación es doble:

1. Usar GQM para disciplinar la proliferación de métricas.
2. Usar PRAGMATIC para honestar el debate sobre qué indicadores merecen sobrevivir. [web:39]
[web:45]

Si, en el proceso, descubrimos que algunas de las métricas favoritas de los últimos años son poco predictivas, poco accionables o muy caras de conseguir, no pasa nada: también las métricas, como los sistemas, necesitan de vez en cuando una jubilación digna.